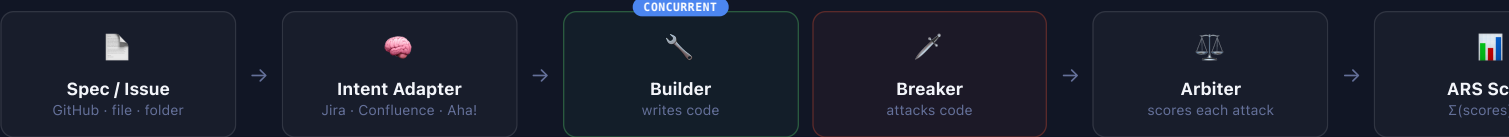


Generates code and adversarial attacks from the same specification, at the same time — before a commit exists.

Builder and Breaker run concurrently on one spec. Arbiter scores every attack individually. A gate blocks the CI pipeline when the score falls below threshold — the same enforcement discipline as a failing test suite, applied to security. No manual test authoring, no separate security review step.

⚡ How GAUNTLEX Works — Live Pipeline

Each run executes this pipeline end to end. Builder and Breaker run **concurrently** — the attack surface is reasoned from the specification alone, before either implementation exists. 7 minutes, gated automatically before code ever reaches a reviewer.



~4–5 min

MEDIAN RUN TIME, QUICK MODE — FASTER THAN A HUMAN SECURITY REVIEW STARTS

ARS < 0.80

DEFAULT HARD GATE THRESHOLD — CONFIGURABLE PER TEAM

SHA-256

TAMPER-EVIDENT REPORT — VERIFIABLE BY ANY AUDITOR, ON DEMAND

22

FULL

WHERE THIS SITS RELATIVE TO EXISTING TOOLING

SAST, DAST, and penetration testing test code **after it exists** — after a PR opens, after deployment, after months in production. GAUNTLEX runs at the generation event itself, gating tools have anchored to an implementation. It does not replace them; it closes the window before they start.

Coverage across languages, compliance domains, and the enterprise controls a security team actually needs

LANGUAGES — AUTO-DETECTED

5 languages, each with its own CWE priority list

Detected directly from the spec — no per-project configuration.

Example: **prototype pollution** (CWE-1321) prioritized for JavaScript; **nil-pointer dereference** (CWE-476) for Go — language-appropriate, not generic.

Python

JavaScript

TypeScript

Java

Go

COMPLIANCE DOMAINS — BUILT IN

5 regulated-industry playbooks, audit-mapped

Every report carries the control-framework references an auditor actually asks for — NIST SSDF, OWASP SAMM, SOC 2, and ISO 27001 — alongside each finding's CWE, not instead of it. Additional domains added via a single YAML file, same schema.

Each playbook maps to the source regulation directly — e.g. FINRA Rules 4370/3110, HIPAA Security Rule (45 CFR 160/164), PCI DSS v4.0.

FINRA

HIPAA

OWASP Top 10

PCI DSS

SOC 2

MCP SERVER — NATIVE

Connects directly already uses

One command wires it in to context-switch into.

Exposes five tools over t stats, policy list, and inte

Claude Code

Cursor

CI/CD — PIPELINE-NATIVE

Gates the merge, not just the conversation

SARIF for code scanning, JUnit XML for test reporting — every attack becomes a test case your CI already knows how to fail on.

SARIF output uploads directly to GitHub Code Scanning; JUnit XML is read by any CI dashboard already parsing test results.

GitHub Actions

Jenkins

GitLab CI

CircleCI

ENTERPRISE CONTROLS — TEAM-READY

RBAC, audit trail, and air-gapped deployment out of the box

gauntlex serve --rbac — GitHub team-based access control (admin / reviewer / developer) across a shared instance.

gauntlex audit — every run listed with full compliance control mapping for a configurable window. Runs fully air-gapped with zero outbound calls when required.

RBAC

Audit trail

Air-gapped

DASHBOARD + LEADERBO

Every run tracked

Foreground and backgro polling required, one URL

Live leaderboard ranks re — the same view used to secure code by default.

HTML export

SARIF